1 işletim sistemi ve şifreleme

ssh key dediğimiz olay aslında dijital bir anahtar kilit ilişkisi gibi çalışıyor parola kullanınca saldırgan deneme yanılma yaparak şifreni bulabilir ama ssh key sisteminde bilgisayarında çok karmaşık bir gizli anahtar var sunucuya ise bunun açık anahtarını veriyorsun bağlanırken bu iki anahtar matematiksel olarak tokalaşıyor anahtarın kopyası sende olduğu için çalınması çok daha zor yani brute force falan sökmez bu sisteme

hex dump meselesi ise bilgisayarın konuştuğu dili yani 0 ve 1leri bizim anlayacağımız onaltılık sayı sistemine dökme işidir bir dosyayı normalde açamazsın ama hex dump yapınca dosyanın gerçekte ne olduğunu anlarsın mesela bir resim dosyasının içine gizlenmiş bir metin mi var yoksa dosya aslında bir zip mi bunu en iyi buradan görürüz özellikle gizli flagleri bulurken hayat kurtarır

2 web mimarisi ve sunucu tarafı

client side dediğimiz olay senin tarayıcında bitiyor yani html ve js kodlarını tarayıcı indirip sana gösterdiği için sağ tık yapınca her şeyi görebiliyorsun ama php veya python gibi diller sunucunun kendi mutfağında çalışır sunucu bu kodları işler sana sadece sonucunu yollar yani yemeğin tarifini değil sadece tabaktaki halini görürsün bu yüzden arka plandaki o gizli kodlara erişemiyoruz

command injection ise tam bir yazılımcı hatası diyebiliriz site senden bir veri bekliyor diyelim ama sen o kutucuğa sadece metin değil de yanına linux komutlarını ayıran işaretleri koyuyorsun mesela noktalı virgül ekleyip yanına ls yazıyorsun sistem senin yazdığını kontrol etmeden direkt terminale gönderirse senin masum araman bir anda sunucunun içindeki dosyaları listeleyen bir saldırıya dönüşüyor

3 ağ anatomisi ve izler

c2 sunucusu dediğimiz yer hackerın ana karargahıdır bir bilgisayara virüs bulaştığında o virüs tek başına ne yapacağını bilemez sürekli bu c2 sunucusuna bağlanıp yeni emir var mı diye sorar buna beaconing denir eğer bu bağlantı koparsa hacker kurban üzerindeki kontrolünü kaybeder o yüzden bütün olay bu trafikte biter

pcap analizi ise ağın röntgenini çekmek gibidir antivirüsler bazen kandırılabilir ya da devre dışı bırakılabilir ama ağ trafiği yalan söylemez bir soc analisti pcap dosyasına baktığında

hangi bilgisayar nereye ne göndermiş şifreli mi gitmiş açık mı gitmiş her şeyi görür paketlerin içindeki gerçek veriyi yakaladığı için saldırının tam kanıtını buradan çıkarır

Bölüm B

Cephe 1

Sisteme giriş yaptıktan sonra data.txt dosyasını inceledim. İçindeki metnin anlamsız olduğunu gördüm. ROT13 mantığını (alfabeyi 13 karakter öteleme) kullanarak tr komutuyla bir eşleme yaptım. Neden CyberChef kullanmadım? Çünkü bir mühendis olarak terminalde kalmak hem daha hızlı hem de verinin dışarı sızmasını engeller. tr komutuyla A'yı N'ye, B'yi O'ya çevirerek orijinal şifreye ulaştım.

```
bandit11@bandit:~$ ls
data.txt
bandit11@bandit:~$ cat data.txt
Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4
bandit11@bandit:~$ cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m'
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
bandit11@bandit:~$ AnkaSec
```

Dosya isimleri her dekompresyon adımında değişse de (data2.bin, data4.bin vb.), file komutuyla dosya imzalarını takip ederek doğru araçları kullanmaya devam ettim. Bu aşamada gzip katmanını başarıyla eledim.

```
bandit12@bandit:~$ ls
data.txt
bandit12@bandit:~$ mktemp -d
/tmp/tmp.5BKweVp2Yn
bandit12@bandit:~$ cd /tmp/tmp/5BKweVp2Yn
-bash: cd: /tmp/tmp/5BKweVp2Yn: No such file or directory
bandit12@bandit:~$ cd /tmp/tmp.5BKweVp2Yn
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$  ls
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ cp ~/data.txt
cp: missing destination file operand after '/home/bandit12/data.txt'
Try 'cp --help' for more information.
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ xxd -r data.txt > data
xxd: data.txt: No such file or directory
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ cp ~/data.txt .
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ xxd -r data.txt > data
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data
data: gzip compressed data, was "data2.bin", last modified: Tue Oct 14 09:26:00 2025, max compression, from Unix, original size modulo 2^3
2 572
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ mv data data.gz
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ gzip -d data.gz
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls
data  data.txt
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data
data: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ bzip2 -d data
bzip2: Can't guess original name for data -- using data.out
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls
data.out  data.txt
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data.out
data.out: gzip compressed data, was "data4.bin", last modified: Tue Oct 14 09:26:00 2025, max compression, from Unix, original size modulo
 2^32 20480
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ mv data.out data.gz
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ gzip -d data.gz
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls
data  data.txt
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data
data: POSIX tar archive (GNU)
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ tar xf data
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls
data  data5.bin  data.txt
bandit12@bandit:/tmp/tmp.5BKweVp2Yn$
```

Devamı :

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data5.bin

data5.bin: POSIX tar archive (GNU)

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ tar xf data5.bin

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls

data data5.bin data6.bin data.txt

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data6.bin

data6.bin: bzip2 compressed data, block size = 900k

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ bzip2 -d data6.bin

bzip2: Can't guess original name for data6.bin -- using data6.bin.out

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls

data data5.bin data6.bin.out data.txt

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data6.bin.out

data6.bin.out: POSIX tar archive (GNU)

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ tar xf data6.bin.out

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls

data data5.bin data6.bin.out data8.bin data.txt

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data8.bin

data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:00 2025, max compression, from Unix, original size modulo 2^32 49

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ mv data8.bin data.gz

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ gzip -d data.gz

gzip: data already exists; do you wish to overwrite (y or n)? y

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ ls

data data5.bin data6.bin.out data.txt

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ file data

data: ASCII text

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$ cat data

The password is FO5dwFsc0cbaIiH0h8J2eUks2vdTDwAn

bandit12@bandit:/tmp/tmp.5BKweVp2Yn$

```
bandit14@bandit:~$ nc localhost 30000
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

```
┌──(device㉿kali)-[~]
└─$ curl -I http://www.admin.ankasec.co/.env~
HTTP/1.1 403 Forbidden
Connection: close
Content-Type: text/html
Cache-Control: no-cache
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Security-Policy: frame-ancestors 'self'
Content-Length: 5305

┌──(device㉿kali)-[~]
└─$ curl -I -A "Googlebot/2.1 (+http://www.google.com/bot.html)"
http://www.admin.ankasec.co/.env~
HTTP/1.1 403 Forbidden
Connection: close
Content-Type: text/html
Cache-Control: no-cache
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Security-Policy: frame-ancestors 'self'
```

Content-Length: 5305

```
┌──(device㉿kali)-[~]
└─$ curl -I http://www.admin.ankasec.co/.ENV~
HTTP/1.1 403 Forbidden
Connection: close
Content-Type: text/html
Cache-Control: no-cache
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Security-Policy: frame-ancestors 'self'
Content-Length: 5305
```

Daha önce Ankasec.co içinde yaptığım denemlerde xss ve sql e rastlamadım